PORTFOLIO TECHNICAL & COMMERCIAL AUDIT

Full Audit Report

taptoglass.com

A Fortune 500–standard assessment of the WaterQualityLens address-level tap-water intelligence property: front-end architecture, data layer, brand system, SEO, accessibility, security posture, privacy compliance and monetization readiness.

C+	A–	D+
OVERALL GRADE	ENGINEERING CRAFT	LAUNCH READINESS

Audit date: 29 August 2026

Codebase: kevynsgrin-a11y/WaterLens @ 79424b3

00 Scope, Method & Evidence Standard

This audit was conducted against the deployed codebase for taptoglass.com. Every finding below is traceable to a file, a build artifact, or a command output reproduced in this document. Nothing is asserted from memory.

Method actually executed

The audit environment had **no outbound web egress**. The network policy governing this session refused `CONNECT` to every external host tested, including the target domain and a neutral control:

EGRESS VERIFICATION — PROXY STATUS ENDPOINT

```
"recentRelayFailures": [ {
  "kind": "connect_rejected",
  "detail": "gateway answered 403 to CONNECT (policy denial or upstream failure)",
  "host": "taptoglass.com:443"
} ]

$ WebFetch https://example.com/   →  EGRESS_BLOCKED  (control host also refused)
```

This is a restriction of the audit environment, **not** evidence about the site's availability. Because live probing was impossible, the audit was re-based on the strongest evidence actually obtainable: the source of record plus a **real production build** executed locally. That build is the primary evidence for every rendered artifact cited here — the emitted `<head>`, `robots.txt`, `sitemap.xml`, `manifest.webmanifest`, route table and byte-level asset sizes are all measured, not estimated.

> **Two dimensions cannot be graded from source**
>
> **Indexing & Discoverability** and **measured Core Web Vitals** require a live origin and live search-engine state. They are reported as *NOT VERIFIED* rather than assigned a speculative grade. Every other dimension is graded on measured evidence. **Served** security headers are likewise unverifiable: the configuration is graded, with the caveat that a CDN or static export in front of the app could add or strip headers.

Evidence base

Source of record	kevynsgrin-a11y/WaterLens, branch `main`, commit `79424b3`
Build executed	`next build` — compiled successfully, 47 static pages generated
Typecheck	`tsc --noEmit` — clean on both frontend and backend
Test suite	`vitest run` — 45/45 passing across 5 files
Artifacts read	Generated `robots.txt`, `sitemap.xml`, `manifest.webmanifest`, prerendered HTML for 11 routes, full static asset manifest

Grading scale

Applied at the standard of a funded consumer web property, not a side project. A dimension is graded on what a paying user or a search engine actually receives.

GRADE	BAND	DEFINITION
A	90–100	Ships at Fortune 500 standard. No material defect. Would survive external review.
B	80–89	Strong. Defects are known, bounded, and do not block launch or revenue.
C	70–79	Functional, but with material gaps that cap scale, trust, or monetization.
D	60–69	Significant defects. Remediation required before the dimension can be relied on.
F	<60	Not fit for purpose.

01 Executive Summary

taptoglass.com is a genuinely well-engineered front-end wrapped around a data layer that cannot yet fulfil the product's central promise. The craft is top-decile; the substance is pre-launch. That gap — not any individual bug — is the finding that governs this report.

The headline

The site invites the visitor to "enter your US home address." In the shipped build, exactly **three** water systems resolve to a full report: Flint MI, Newark NJ, and a Travis County TX district. Every other US address falls through to a ZIP-registry path that returns violations but **zero contaminant detections** — and because the filter-matching engine keys strictly off detections, it therefore returns **zero filter recommendations**. Outside three cities the product shows no hardware, which means it also earns no affiliate revenue.

> **The commercial consequence, stated plainly**
>
> The monetization surface is live for approximately **0.1% of the US population** by construction. This is not a traffic problem or a conversion problem — it is a coverage problem in `web/lib/data.ts`, where `DEMO_SYSTEMS` contains three hand-written entries. Until that table is fed by the real ingestion pipeline, no amount of SEO or content work can produce revenue.

What is genuinely excellent

The engineering deserves explicit credit. The shared JavaScript payload is **87.1 kB** — roughly half the Next.js median. There are no third-party scripts, no analytics, no ad tech, no cookies, and no web fonts fetched over the network. Accessibility is not retrofitted: skip link, correct landmarks, `aria-invalid`/`aria-describedby` error wiring, Escape-to-close with focus return, a reduced-motion floor, and a no-JS fallback that renders content visible rather than trapping it behind an observer that will never fire. The affiliate disclosure is better than most public companies manage. The set-cover recommendation engine refuses partial matches on principle and isolates NSF 42/372 so an aesthetic certification can never satisfy a health hazard — a defensible, genuinely differentiated position.

What blocks launch

1. **Domain/brand mismatch.** Every user-visible string, the manifest, the copyright line and the affiliate redirect domain say "WaterQualityLens." The domain is taptoglass.com. The canonical origin *defaults* to `waterqualitylens.com` and there is no environment file or deploy config in the repository that sets it otherwise.
2. **No privacy policy, no terms, no contact method.** The legal page is a self-described summary that "does not replace formal terms." There is no email address anywhere on the site. For a YMYL health topic this is an E-E-A-T liability, and it independently disqualifies the site from AdSense and most affiliate programs.
3. **Undisclosed third-party data transmission.** User-entered home addresses are sent to the US Census geocoder and EPA Envirofacts. Neither is mentioned in the privacy summary.
4. **Data coverage.** Three systems, as above.

Overall grade: C+

The front-end, taken alone, earns an A−. The property as a whole cannot be graded on its front-end, because a visitor outside three cities receives an empty result and a visitor anywhere receives no privacy policy. The overall grade reflects a site that is **architecturally ready and substantively not**. The remediation path is unusually short: most of the gap is configuration, content, and one data-ingestion connection — not rearchitecture.

02 Dimensional Scorecard

DIMENSION	GRADE	BAND	GOVERNING FINDING
Visual Design & Brand	B+	87	Token system and dark-mode handling are A-grade craft; brand identity contradicts the domain on every page.
UX / Information Architecture	B+	86	Answer-first report design and honest confidence tiering; no coverage expectation set before the user invests an address.
Front-end Architecture	A−	91	Server-first, tiny client islands, single source of truth for origin, clean typecheck. Zero frontend tests.
Performance & Assets	A−	90	87.1 kB shared JS, self-hosted preloaded fonts, no raster images. CSS at 58.4 kB and 164 kB HTML documents are the soft spots.
Back-end / Data Layer	C+	75	Two disconnected backends. The Worker is well-built but undeployed (placeholder IDs); the web app ships three hardcoded systems.
SEO Foundations	B−	81	Canonical, OG, sitemap and robots are correctly implemented; the origin default points at the wrong domain and entity pages carry no schema.
Indexing & Discoverability	NOT VERIFIED	—	Requires live search-engine state. No egress available. See §00.
Accessibility	A−	90	Deliberate, systemic, and documented in code comments. Mobile nav lacks a focus trap.
Security Headers	B+	87	Comprehensive header set including HSTS preload and COOP. `script-src 'unsafe-inline'` is the material weakness.
Privacy & Compliance	C−	70	Excellent zero-tracking posture undermined by no policy, no contact, no disclosure of third-party address transmission.
Content Quality & Depth	B	83	27 substantive contaminant entities averaging ~1,050 words. Only 3 PWS pages — the programmatic engine has no fuel.
PWA / Mobile Experience	C+	76	Manifest declares an icon path that does not exist in the build. No 192/512 PNG icons, so not installable.
Monetization Readiness	C−	68	Disclosure quality is exemplary; the revenue surface is inert outside three cities.
OVERALL	**C+**	**78**	**Exceptional craft, pre-launch substance. Short remediation path.**

How to read this scorecard

The spread between Front-end Architecture (A−) and Monetization Readiness (C−) is the whole story of this property. Nothing here suggests the team cannot build. It suggests the build ran ahead of the data, the legal scaffolding, and the brand decision. Those three are the entire gap.

03 Technical Stack Identification

Identified precisely from `package.json`, lockfiles, build output and source. No inference where a version string was available.

LAYER	TECHNOLOGY	EVIDENCE & NOTES
Framework	Next.js **14.2.15** (App Router)	Build banner `▲ Next.js 14.2.15`. React Server Components by default.
UI runtime	React 18.3.1 / React-DOM 18.3.1	Pinned exact, not caret — deliberate.
Language	TypeScript 5.5.3 (web) / 5.6.2 (worker)	Both typecheck clean under `--noEmit`.
Styling	Tailwind CSS 3.4.10 + PostCSS 8.4.39	Custom token layer; `darkMode: ["class", '[data-theme="dark"]']`.
Typography	Inter Variable + JetBrains Mono Variable	Self-hosted `.woff2` via `next/font/local`. 47.1 kB + 39.5 kB. No CDN.
Share images	`next/og` (Satori)	OG card and Apple icon rendered at build time. No raster assets in repo.
Server boundary	`server-only` 0.0.1	Correctly guards `lib/lookup.ts` from client import.
Intended backend	Cloudflare Workers + D1 + KV + Queues + Cron	`wrangler.toml`; Workers runtime, `nodejs_compat`.
Backend testing	Vitest 2.1.9	45 tests, 5 files, all passing.
Third-party runtime	**None**	No analytics, tag manager, ad script, font CDN, or XHR target beyond own origin.

Architectural note worth preserving

The zero-third-party posture is a real asset and is rare. It is what makes the strict CSP genuinely enforceable, keeps the privacy story clean, and holds the JS payload at half the framework median. Any future analytics or ad decision should be weighed against the loss of all three.

The two-backend problem

The repository contains two independent implementations of the same domain logic:

- `src/` — a Cloudflare Worker with D1 schema, SDWIS ingestion, queues, cron triggers, auth, and a premium vault. Well-structured, 45 tests.
- `web/lib/` — a re-implementation of geocoding, spatial resolution and set-cover matching that runs inside Next.js against bundled data.

The Worker is **not deployed**. Its configuration still carries placeholder bindings:

WRANGLER.TOML — UNPOPULATED BINDINGS

```
database_id = "REPLACE_WITH_D1_DATABASE_ID"
id          = "REPLACE_WITH_KV_NAMESPACE_ID"
```

The live site therefore runs entirely on the Next.js re-implementation and its three bundled systems. The Worker's ingestion pipeline — the component that would give the site national coverage — has never run against production infrastructure. This is the single highest-leverage item in the entire audit.

04 Visual Design & Brand System B+

What the design system does well

This is a properly constructed token system, not Tailwind defaults with a brand colour swapped in. Four semantic ramps (`brand`, `verdant`, `ink`, `caution`) sit above three theme-aware surface variables resolved in CSS custom properties, so light and dark are defined in one place and every component consumes semantics rather than hexes.

Several decisions show unusual discipline:

- **Alarm colours are barred by policy.** There is no red in the palette. The single sanctioned amber surface is the Tier-3 mapping-ambiguity banner. For a category whose competitors trade on fear, this is a brand position encoded in the token file.
- **A real elevation ramp** with brand-tinted shadow colour (`e1 → card → lift → overlay`), so cards read as raised surfaces rather than outlined rectangles.
- **Fluid display type** with optical tracking that tightens as size grows (`-0.03em` at display-1), plus `text-wrap: balance` on headings and tabular numerals on all data.
- **Dark mode handles all three states correctly** — explicit light, explicit dark, and OS-preference — with a pre-paint bootstrap that stamps `data-theme` before first paint, eliminating flash.
- **A print stylesheet exists and is thoughtful.** It strips chrome, forces light surfaces, expands link hrefs, and sets `break-inside: avoid` on evidence blocks. The stated intent — that a resident can take the report to a landlord or council meeting — is actually implemented.

Why this is not an A

The brand does not match the domain

Every rendered title, the application name, the manifest, the JSON-LD Organization node, the footer copyright and the affiliate redirect subdomain all read **WaterQualityLens**. The property is **taptoglass.com**. A consumer brand whose name never appears on its own site has no brand system at all, however good the tokens are. Measured from the built HTML:

BUILT OUTPUT — /INDEX.HTML <HEAD>

```
<title>WaterQualityLens — What's in your tap water, and what removes it</title>
<meta name="application-name" content="WaterQualityLens"/>
```

BUILT OUTPUT — /MANIFEST.WEBMANIFEST

```
"name":"WaterQualityLens — address-level tap water quality intelligence"
"short_name":"WaterQualityLens"
```

WEB/LIB/DATA.TS — AFFILIATE REDIRECT HOST

```
affiliate_url: "https://affil.waterqualitylens.com/frizzlife-m800"
```

Secondary deductions: there is no logo lockup or brand-asset file beyond an inline SVG mark; `DESIGN.md` documents intent but there is no distributable brand guideline; and the OG share card carries the wrong name, so every social impression reinforces the mismatch.

05 UX & Information Architecture B+

Information architecture

Flat, legible, and correctly scoped for a utility. Seven top-level destinations, each with a clear job: the lookup (`/`), the report (`/results`), two entity indexes (`/pws`, `/contaminants`), a commercial registry (`/registry`), and two institutional pages (`/methodology`, `/about`) plus `/legal`. Breadcrumbs are present on institutional and entity pages and emit matching `BreadcrumbList` JSON-LD from the same array — so the visible trail and the structured data cannot drift apart. That is a detail most teams get wrong.

The report experience

The results page is the product, and it is well-designed. The verdict comes first, above the fold, before any explanation. A confidence banner states the match tier in plain language and does not hide a low-confidence result. Commercial hardware is deliberately rendered *after* the objective data — the ordering is enforced in the component tree and commented as policy. Four distinct empty states are implemented (*no address*, *no match*, *clean water*, *no samples*) rather than one generic blank.

> **Honest uncertainty as a design principle**
>
> The three-tier confidence model is surfaced to the user with its numeric confidence, a human label, and — at Tier 3 — a warning banner plus lab-test advice. Most tools in this category present a single unqualified answer. Showing the seam is the harder and better choice, and it is the site's strongest trust asset.

Where UX loses points

1. **No coverage expectation is set before the ask.** The hero invites any US address. Three will work fully. A user in Denver enters their home address, waits, and receives a result with no contaminants and no filters — indistinguishable, to them, from "your water is fine." That is the most damaging possible failure mode for a trust-first brand.
2. **The example addresses conceal the limit.** Flint, Newark and Austin are offered as samples; all three are inside coverage. The samples demonstrate a capability the product does not generally have.
3. **`/pws` is thin** — 394 rendered words listing three systems. It reads as a placeholder, because it is one.
4. **No filtering or search on `/contaminants`** (27 entries) or `/registry`. Fine now; a scale problem the moment coverage grows.
5. **No persistence.** No saved addresses, no recent lookups, no share link affordance — though the Worker backend implements saved addresses and alerts, none of it is reachable from the web UI.

06 Front-end Architecture A−

The strongest dimension in the audit. Server-first by default, with client interactivity confined to four small islands.

Composition

Only four components carry `"use client"`: `AddressSearch`, `ThemeToggle`, `MobileNav`, and `Reveal`. Everything else — including all entity pages, the entire results report, and every data visualisation — renders on the server. The measured consequence is a homepage route contributing **2.71 kB** on top of the shared bundle.

NEXT BUILD — ROUTE TABLE (EXCERPT)

```
Route (app)                         Size      First Load JS
┌ ○ /                                2.71 kB   96.6 kB
├ ● /contaminants/[code]             199 B     94.1 kB    [27 paths prerendered]
├ ● /pws/[pwsid]                     199 B     94.1 kB    [3 paths prerendered]
├ ƒ /results                         3.02 kB   96.9 kB
└ ƒ /api/lookup                      0 B       0 B
+ First Load JS shared by all                  87.1 kB
```

Discipline worth noting

- **Single source of truth for the origin.** `lib/site.ts` exists specifically because the URL was previously duplicated across layout, sitemap and robots — and the fix is documented in the file's own comment. The pattern is right; only its default value is wrong (§08).
- **`server-only` is actually used**, so the lookup engine cannot be pulled into a client bundle by accident.
- **The sitemap's indexability gate mirrors the page's**, with a comment in both files instructing that they must stay in step — a real crawl-budget concern, handled deliberately.
- **Progressive enhancement is explicit.** The scroll-reveal hidden state is gated behind a `.js` class set by the bootstrap script, so with scripting disabled every section renders visible. The comment states the principle: "an animation must never be the thing that decides whether a section can be read."

Deductions

- **Zero frontend tests.** The backend has 45; `web/` has none. The set-cover engine, the tier resolver and the exceedance math were all re-implemented in `web/lib/` and are entirely untested there. Two copies of safety-critical logic, one tested.
- **Duplicated domain logic** between `src/services/` and `web/lib/` will drift. It is already inconsistent: the web `resolveSpatial` has no Tier-2 path at all.
- **The theme bootstrap forces `'unsafe-inline'`** in the CSP (§10). Solvable with a nonce or hash.

07 Performance & Assets A–

All figures below are measured from the production build, not estimated.

METRIC	MEASURED	ASSESSMENT
Shared First Load JS	**87.1 kB**	Excellent. Roughly half the Next.js App Router median.
Homepage First Load JS	**96.6 kB**	Excellent for a page with animated SVG and a live form.
Total JS emitted	695.2 kB	Includes a 110 kB legacy polyfill chunk served only to old browsers.
CSS	**58.4 kB**	**SOFT SPOT** Large for this surface area. Uncompressed; ~9–11 kB gzipped, but worth auditing.
Fonts	47.1 kB + 39.5 kB	Self-hosted variable woff2. Sans preloaded, mono correctly *not* preloaded.
Raster images	**0**	41 inline SVGs. No image CLS surface, no `next/image` needed.
HTML document size	59–168 kB	**SOFT SPOT** RSC payload inflates documents. /pws/NJ0714001 is 168 kB for 1,047 words.
Static pages prerendered	47	Only `/results` and `/api/lookup` are dynamic.

Core Web Vitals — reasoned, not measured

> **NOT VERIFIED — field data requires a live origin**
>
> No CrUX or Lighthouse data could be obtained. The following are structural predictions from the build, and should be confirmed with a real Lighthouse run once the origin is reachable.

- **CLS — expected excellent.** No raster images, no ad slots, no embeds, fonts preloaded with `display: swap` and matched fallback stacks. The scroll-reveal animates `opacity` and `transform` only, which do not trigger layout.
- **LCP — excellent on static routes, at risk on `/results`.** The results route is `force-dynamic` and awaits a live Census geocode with an 8-second timeout *inside* the render path. A slow upstream directly becomes a slow LCP. A `loading.tsx` exists, which mitigates perceived latency but not the metric.
- **INP — expected excellent.** Four small client islands; no heavy main-thread work.

Recommendation

Move the geocode + lookup behind a `<Suspense>` boundary so the report shell streams immediately and the data region resolves independently. This converts an upstream-dependent LCP into an upstream-dependent content paint.

08 Back-end & Data Layer C+

The weakest structural dimension, and the one that governs the overall grade. The architecture is sound; the deployment and the data are not.

Data inventory — what actually ships

DATASET	COUNT	ASSESSMENT
Public water systems (`DEMO_SYSTEMS`)	**3**	CRITICAL Flint MI, Newark NJ, Clear Springs TX. Hand-written literals.
Contaminant definitions	27	Solid. MCL, MCLG, unit, category, priority, health-effect narrative each.
Filter SKUs	11	Reasonable seed. Each with form factor, price, capacity, affiliate URL.
Certification claims	27 rows	Per-SKU, per-standard, per-contaminant, with certifier attribution.
NSF/ANSI standards modelled	6	42, 53, 58, 401, 372 + retired P473 correctly flagged obsolete.

The coverage cliff, traced through the code

A lookup outside the three bundled polygons follows this path:

WEB/LIB/LOOKUP.TS — ZIPFALLBACK()

```
// Live path exposes verified violations; sample-level detections require the
// full weekly ingestion (backend), so recommendations key off violation codes.
return assemble(
  query, coordinate, match, primary, [], violations, dwelling, "ZIP_REGISTRY", ...
);                                    ↑ detections = empty array
```

WEB/LIB/ENGINE.TS — MATCHFILTERS()

```
const hazards = new Set(detections.filter(d => d.exceeds_health_goal).map(d => d.code));
if (hazards.size === 0) return [];   ← no detections ⇒ no recommendations
```

The chain is deterministic: outside three systems there are no detections; with no detections there are no hazards; with no hazards the recommendation engine returns an empty array. The user sees a utility name, possibly some violations, and **no filters**. The comment in the source is candid that this awaits "the full weekly ingestion (backend)" — the backend that has never been deployed.

Resilience

Credit where due: geocoding has a genuine fallback. When the Census endpoint fails or times out (8s abort), `gazetteerLookup()` resolves bundled locality centroids so demo-coverage addresses still work, and returns `null` outside that coverage rather than guessing. The comment states the reasoning explicitly. The Worker layer adds `withRetry()` with exponential backoff and KV caching tiered by data volatility (30d geocode / 24h lookup / 7d SDWIS). These are correct instincts.

Defects

1. **No rate limiting anywhere.** `/api/lookup` accepts unbounded requests, each capable of triggering an outbound call to a no-SLA government geocoder. This is both an abuse vector and a route to being blocked by Census.
2. **Worker CORS is fully open.** `src/lib/http.ts` sets `access-control-allow-origin: *` on *every* response, including authenticated vault and saved-address routes, with `authorization` in the allowed headers. Bearer-token auth limits the classic CSRF exposure, but this also means the curated certification dataset — described in the README as the platform's defensive moat — is readable by any origin.
3. **PBKDF2 at 100,000 iterations.** Below the OWASP guidance of 600,000 for PBKDF2-HMAC-SHA256. The construction is otherwise correct: per-user random salt, constant-time comparison, parameters stored with the hash.
4. **Single upstream dependency.** Census geocoding has no commercial fallback outside bundled coverage.

09 SEO Foundations B–

Implemented correctly

The mechanics are genuinely well done. Verified from the built artifacts: self-referencing canonicals on 9 of 10 routes; complete Open Graph and Twitter card sets with a build-generated 1200×630 share image; a data-driven sitemap whose `lastmod` reflects the newest sample date rather than the build time; and a correct `robots.txt`.

BUILT OUTPUT — ROBOTS.TXT (WITH ORIGIN CORRECTLY SET)

```
User-Agent: *
Allow: /
Disallow: /api

Host: https://taptoglass.com
Sitemap: https://taptoglass.com/sitemap.xml
```

The `/results` route is excluded from the index three ways — a per-page `robots` directive, an `X-Robots-Tag` response header, and deliberate *absence* from `robots.txt` `Disallow`. The last is the subtle one, and the source comments explain it: a crawler blocked by `robots.txt` can never read the `noindex`. That is a level of care most audits never find.

The critical SEO defect

> **The canonical origin defaults to the wrong domain**
>
> `web/lib/site.ts` resolves the origin as `process.env.NEXT_PUBLIC_SITE_URL ?? "https://waterqualitylens.com"`. There is **no `.env` file, no `vercel.json`, no CI workflow, and no deployment configuration anywhere in the repository** that sets that variable. If it is not set in the hosting environment, then every canonical tag, every `og:url`, every sitemap entry, the `robots.txt` `Host` and `Sitemap` directives, and every JSON-LD `@id` on taptoglass.com will point at **waterqualitylens.com**. A site whose canonicals all name a different domain is instructing Google to attribute — and potentially consolidate — the entire property elsewhere.

The audit build was run with the variable set explicitly, which is how the correct `taptoglass.com` output above was produced. That demonstrates the mechanism works; it does not demonstrate the variable is set in production. **This must be verified against the live origin as the first action after this audit.**

Structured data coverage

ROUTE	CANONICAL	OG	JSON-LD PRESENT
`/`	✓	✓	Organization, WebSite, SearchAction, FAQPage
`/pws/[pwsid]`	✓	✓	BREADCRUMBLIST ONLY
`/contaminants/[code]`	✓	✓	BREADCRUMBLIST ONLY

`/registry`	✓	✓	**BREADCRUMBLIST ONLY**
`/methodology`, `/about`, `/legal`	✓	✓	BreadcrumbList only
`/results`	n/a — noindex	n/a	None (correct)

For a property whose growth thesis is programmatic entity pages, the absence of entity schema is a significant missed opportunity. `/pws/*` pages carry no `Dataset` or `GovernmentService` markup; `/contaminants/*` carry no `DefinedTerm` or `MedicalWebPage`; `/registry` carries no `ItemList`/`Product`. These are the pages built to rank, and they are the pages with the least structured data.

Minor items: `og:site_name` is lost on the homepage because the page-level `openGraph` object overrides the root without re-declaring it; `twitter:title` falls back to the bare brand string rather than the page title; and a `keywords` meta tag is emitted, which is obsolete though harmless.

10 Indexing & Discoverability NOT VERIFIED

This dimension cannot be graded in this environment

Establishing index status requires live `site:` queries against Google and Bing, Search Console access, or at minimum a live fetch of the origin. All outbound HTTP was refused by the session's egress policy (§00). Assigning a grade here would mean fabricating the evidence, which would make the entire scorecard untrustworthy. It is therefore reported as unverified.

What can legitimately be said

- A general web search for the domain returned **no results** for taptoglass.com — only similarly-named unrelated domains. This is weak evidence: the search tool is not a `site:` operator and its index may lag. It is *consistent with* a site that is new or not yet indexed, but does not establish it.
- The repository contains **no deployment configuration of any kind** — no CI workflow, no `vercel.json`, no `netlify.toml`, no environment file. Nothing in the source establishes that a deploy has occurred.
- The **indexable surface is 37 URLs**: 7 static routes, 27 contaminant pages, and 3 PWS pages (the sitemap's quality gate admits all three, each having ≥1 detection and ≥2 history points).

Required verification — first actions once the origin is reachable

1. `curl -I https://taptoglass.com/` — confirm the origin resolves and capture the served header set.
2. Fetch `/robots.txt` and `/sitemap.xml` and confirm both name **taptoglass.com**, not waterqualitylens.com. This is the single most important check in the entire audit.
3. `site:taptoglass.com` on Google and Bing — record indexed count against the expected 37.
4. Register the property in Google Search Console and Bing Webmaster Tools; submit the sitemap; check the Page Indexing report for "Duplicate, Google chose different canonical," which is the signature of the origin defect in §09.

11 Accessibility A–

Accessibility here is systemic rather than retrofitted, and in several places the reasoning is documented in the code itself. This is the dimension most likely to survive external audit unchanged.

Verified implementations

AREA	EVIDENCE
Skip link	First focusable element; `sr-only` until focused, then fully styled.
Landmarks	`<main id="main">`, `<nav aria-label>` on primary/mobile/breadcrumb, `role="search"` on the lookup form.
Form semantics	`sr-only` label bound by `useId`; `autoComplete="street-address"`; `aria-invalid` + `aria-describedby` on error; error node carries `role="alert"`.
Grouped controls	Dwelling selector uses `<fieldset>` + `<legend>` with `aria-pressed` per option.
Disclosure pattern	Mobile nav: `aria-expanded`, `aria-controls`, dynamic `aria-label`, Escape closes and returns focus to trigger.
Current page	`aria-current="page"` in nav and breadcrumbs.
Decorative graphics	78 `aria-hidden="true"` occurrences across 41 inline SVGs. No raster images, so no missing `alt` is possible.
Focus visibility	`:focus-visible` ring follows each element's own radius, with a contextual `--ring-offset` so it never draws a white halo on dark bands.
WCAG 2.2 SC 2.4.11	`scroll-margin-top: 5rem` applied to all focusable and id-bearing elements to clear the sticky header. Explicitly commented as such.
Motion	`prefers-reduced-motion` reduces all animation to 0.01ms and disables smooth scrolling; reveal start-state is neutralised.
No-JS	Reveal hidden-state gated behind a `.js` class, so content renders visible without scripting.
Data legibility	`font-variant-numeric: tabular-nums` on all numeric output; `ink-500` documented as darkened to clear 4.5:1 on the canvas.

Deductions

- **No focus trap in the mobile navigation panel.** Escape and focus return are handled, but focus is never moved into the open panel and can tab out of it into the page behind. This is the one clear WCAG gap.

- **Dwelling selector uses `aria-pressed` toggle buttons** for what is semantically a single-select group. A `radiogroup` with roving tabindex, or native radios, would convey "choose one of three" correctly.
- **No `aria-live` region for the lookup transition.** The button label changes to "Checking…" but a screen-reader user gets no announcement that a report is loading or has arrived.
- **Unverifiable without a browser:** computed contrast of `text-brand-200/85` on the navy inverse bands, and real focus-order traversal. Both need a live Axe/Lighthouse pass.

12 Security Headers B+

Configuration graded; delivery unverified

The following is read from `web/next.config.mjs`. Headers declared in `next.config` are only emitted when the app is served by the Next.js runtime. A static export, or a CDN/proxy in front of the origin, can drop or override them. **Confirm with `curl -I` against the live origin.**

HEADER	SET	VALUE & ASSESSMENT
Content-Security-Policy	PARTIAL	Strict on every directive except `script-src 'unsafe-inline'`. See below.
Strict-Transport-Security	YES	`max-age=63072000; includeSubDomains; preload` — 2 years, preload-eligible. Correct.
X-Content-Type-Options	YES	`nosniff`.
Referrer-Policy	YES	`strict-origin-when-cross-origin` — appropriate.
X-Frame-Options	YES	`SAMEORIGIN`, consistent with CSP `frame-ancestors 'self'`.
Permissions-Policy	YES	`geolocation=(), camera=(), microphone=(), payment=(), usb=()`.
Cross-Origin-Opener-Policy	YES	`same-origin`.
X-Robots-Tag	YES	Scoped to `/results` and `/api/*`. Correct use.
X-Powered-By	REMOVED	`poweredByHeader: false`.
Cross-Origin-Resource-Policy	NO	Absent. Low risk given no cross-origin embedding.
CSP `report-to`	NO	No violation telemetry — CSP failures will be silent.

The CSP weakness

The policy is otherwise genuinely strict — `default-src 'self'`, `object-src 'none'`, `base-uri 'self'`, `connect-src 'self'`, `upgrade-insecure-requests` — and the zero-third-party architecture is what makes that possible. The comment in `next.config.mjs` is honest about why `'unsafe-inline'` is present: Next/Tailwind inject style tags, and the pre-paint theme bootstrap is an inline script.

The `style-src 'unsafe-inline'` is a pragmatic and widely accepted trade-off. The `script-src 'unsafe-inline'` is the material one: it removes CSP's primary defence against injected script. Because there is exactly *one* inline script on the site and its content is a fixed constant, this is unusually easy to fix with a SHA-256 hash — no nonce plumbing required. The verbatim fix is given as Issue 12 in Document 2.

Application-layer security

- GOOD Input validation on `/api/lookup`: length bounds (5–200), a 2 kB body cap checked before parse, JSON parse guarded, and an allowlist for `dwelling_type`.
- GOOD No `dangerouslySetInnerHTML` on user data — only on `JSON.stringify`'d structured data and the constant bootstrap script.
- GOOD Affiliate links carry `rel="sponsored noopener noreferrer"` — correct for both Google policy and tab-nabbing.
- GAP No rate limiting on any route.
- GAP Worker API returns `access-control-allow-origin: *` on authenticated routes.
- GAP PBKDF2 iteration count below current OWASP guidance.

13 Privacy & Compliance C–

An excellent privacy *posture* paired with absent privacy *documentation*. The engineering is more privacy-respecting than the legal text can demonstrate — which is the wrong way round, and it is what caps the grade.

The posture is genuinely strong

- **No analytics of any kind.** No Google Analytics, no tag manager, no Plausible, no Vercel Analytics.
- **No cookies are set.** The only client storage is a single `localStorage` key, `wql-theme`, holding the string "light" or "dark".
- **No third-party scripts, fonts, or pixels.** Verified from the built HTML: every asset is same-origin.
- **No account required** for the core lookup.
- **Geolocation is blocked at the header level** via Permissions-Policy — the site asks for an address rather than reading device location.
- **The FTC affiliate disclosure is exemplary** — present in the footer on every page, restated in full on `/legal`, attached to every generated report, and set at readable size with an explicit code comment that it is "legible, not fine print."

The documentation is not adequate

> **There is no privacy policy and no way to contact anyone**
>
> `/legal` carries a *summary* that explicitly describes itself as not replacing formal terms. A repository-wide search for a contact address, `mailto:` link, or contact page returns **nothing**. For a YMYL health-adjacent topic, Google's quality guidance treats identifiable ownership and contactability as core trust signals — and their absence is independently disqualifying for AdSense and for most affiliate programmes, including Amazon Associates.

REQUIRED ELEMENT	PRESENT	CONSEQUENCE
Formal Privacy Policy	NO	Blocks AdSense; CCPA/GDPR exposure.
Formal Terms of Service	NO	No liability limitation for a YMYL tool.
Contact method	NO	E-E-A-T penalty; no rights-request channel.
Publisher identity / ownership	NO	No named entity behind health guidance.
Third-party data-sharing disclosure	NO	Addresses are sent to Census + EPA, undisclosed.
Cookie / local-storage notice	NO	`localStorage` use undocumented.
Data-retention statement	NO	Silent on whether addresses are logged.

"Last updated" date	NO	Policies cannot be versioned or relied on.
CCPA / GDPR rights section	NO	No documented rights mechanism.
FTC affiliate disclosure	YES	Best-in-class. Preserve exactly as written.
Medical / scope disclaimer	YES	Non-dismissible, on every page and report.

The material omission

Every address a visitor types is transmitted to `geocoding.geo.census.gov`, and ZIP-fallback lookups additionally query `data.epa.gov`. Both are US government endpoints and neither is a commercial data broker — this is a benign design. But it is **third-party transmission of user-entered residential addresses**, and the privacy summary states only that an address "is not sold." Users are not told their address leaves the site at all. Verbatim remediation is given as Issue 7 in Document 2.

14 Content Quality, Depth & Topical Authority B

Measured word counts from the rendered production build — not source estimates.

ROUTE	RENDERED WORDS	ASSESSMENT
`/methodology`	**1,260**	The site's strongest asset. Genuine methodological transparency.
`/contaminants/PB90` (Lead)	1,122	Substantive entity page with health-effect narrative and provenance.
`/`	1,117	Good depth for a landing page; carries FAQPage schema.
`/contaminants/PFOA`	1,059	Strong. PFAS is the highest-value topic in the niche.
`/pws/NJ0714001` (Newark)	1,047	Demonstrates the entity-page template works well.
`/contaminants` (index)	872	Reasonable hub page.
`/registry`	856	Differentiated content — the deceptive-certification angle.
`/legal`	756	Well-written, but a summary rather than a policy (§13).
`/about`	582	Thin, and carries no named author or credentials.
`/pws` (index)	**394**	THIN Three entries. Reads as a placeholder.

Strengths

The editorial position is the product's real moat. Three ideas are executed consistently and are genuinely hard for a competitor to copy:

1. **Provenance on every number.** Each detection carries value, unit, sample date, testing agency, MCL and MCLG. Nothing is asserted without its source.
2. **Certification literacy.** The site teaches that NSF 42 and 372 cannot satisfy a health contaminant, and the `/registry` page names SKUs that market those standards with no health certification. This is consumer-protection content with commercial utility — an unusual and defensible combination.
3. **Refusal of artificial precision.** Partial filter matches are programmatically eliminated rather than shown with a caveat. The nitrate/nitrite warning explicitly tells users that carbon filters *will not* protect them — advice that steers toward the more expensive product for a defensible technical reason, which is the correct way to hold that tension.

Gaps

- **No author, no credentials, no named publisher.** For YMYL content this is the largest E-E-A-T deficit on the site, larger than any technical SEO item.

- **No outbound citations.** EPA, NSF and TEMM are named but never linked. Authoritative outbound links are a positive quality signal, and their absence on a data-provenance site is conspicuous.
- **Three entity pages.** The programmatic template is good; there is nothing to run it on.
- **No editorial layer.** No guides, no comparisons, no "how to read your CCR," nothing targeting the informational queries that would feed the tool.
- **No freshness signals.** No "last reviewed" dates on entity pages.

15 PWA & Mobile Experience C+

Verified manifest defect

The manifest advertises an icon that does not exist

The generated manifest declares `"src": "/apple-icon.png"`. The build emits no such route. The only icon route produced is `/apple-icon`. Confirmed against the build's own route manifest:

.NEXT/SERVER/APP-PATHS-MANIFEST.JSON

```
"/icon.svg/route":            "app/icon.svg/route.js"
"/manifest.webmanifest/route": "app/manifest.webmanifest/route.js"
"/apple-icon/route":           "app/apple-icon/route.js"   ← no .png variant exists
```

GENERATED MANIFEST.WEBMANIFEST

```
"icons":[
  {"src":"/icon.svg","sizes":"any","type":"image/svg+xml","purpose":"any"},
  {"src":"/apple-icon.png","sizes":"180x180","type":"image/png"}   ← 404
]
```

The irony is that the source comment on `apple-icon.tsx` states "The manifest advertises this path, so without it every page load 404s on the icon request" — the author anticipated exactly this failure and the path still does not match. The HTML `<link rel="apple-touch-icon">` is correct (`/apple-icon?hash`); only the manifest entry is wrong.

Installability

Chrome requires a 192×192 and a 512×512 PNG icon for install eligibility. The manifest offers an SVG plus one 180×180 PNG that 404s. **The site is therefore not installable**, despite declaring `display: standalone`. Also absent: any `purpose: "maskable"` icon (Android will letterbox the icon inside a white circle), `screenshots` (which unlock Chrome's richer install dialog), and the `id`, `scope` and `orientation` fields.

Mobile experience — strong independent of PWA status

- Viewport correctly declared with no `maximum-scale`, so pinch-zoom is not disabled — a common and serious accessibility error that this site avoids.
- `theme-color` declared per colour scheme, so the browser chrome matches the active theme.
- The mobile navigation disclosure exists specifically because the links were previously hidden below `md` with no replacement — documented in the component's own comment as a fix.
- Layout is responsive throughout; the search form reflows from row to column, and the results grid collapses predictably.
- No service worker, so no offline capability. Defensible for a network-dependent lookup, but it means "PWA" is aspirational rather than actual.

16 Monetization Readiness C–

What is built

The affiliate infrastructure is real: 11 SKUs each carrying an `affiliate_url`, a redirect subdomain, correct `rel="sponsored noopener noreferrer"`, "Verified Partner" labelling, and a disclosure regime that is better than most public companies manage. The ranking model is defensible and is itself a trust asset — eligibility is decided purely by certification ($D \subseteq \bigcup N_c$) and commercial factors only reorder already-qualified results.

Why it cannot earn

> **The revenue surface is inert outside three cities**
>
> Filter recommendations render only when the engine finds detections exceeding a health goal. Detections exist only for the three bundled systems. Therefore the affiliate module — the site's only revenue mechanism — appears for approximately **0.1% of US addresses**. Fixing coverage (§08) is not a growth initiative; it is the precondition for any revenue at all.

CHANNEL	STATUS	BLOCKING ITEM
Hardware affiliate	BUILT, INERT	Coverage (§08). Also: redirect domain is `affil.waterqualitylens.com`.
Lab-test affiliate (Tap Score)	REFERENCED ONLY	Named in two disclaimers and the README, but there is no link or CTA anywhere in the UI.
Display advertising (AdSense)	BLOCKED	No privacy policy, no contact page. Would be rejected on submission.
Email capture	NONE	No form anywhere. The Worker implements alerts; the web UI exposes none of it.
Premium subscription	BACKEND ONLY	Vault endpoints exist in the undeployed Worker; no UI, no pricing, no checkout.

The highest-value unexploited asset

The Tap Score lab-test path is the most valuable and least developed opportunity on the site. The product's own disclaimers say — correctly and repeatedly — that system-level data cannot detect contamination from household plumbing, and that a point-of-use lab test is the only way to see it. That is a genuine, honestly-argued need, stated at the exact moment the user feels it, with no call to action attached. Lab-test referrals also carry materially higher commissions than filter hardware and, unlike hardware, they are relevant **for every address including those with clean or absent data** — which means this is the one revenue path that works *despite* the coverage gap rather than being blocked by it.

17 Strengths to Preserve

These are load-bearing. Any refactor, redesign, or monetization push should be checked against this list before it ships.

1. The zero-third-party architecture

No analytics, no tag manager, no ad script, no font CDN. This single decision delivers the 87.1 kB bundle, makes the strict CSP enforceable, and gives the privacy story its integrity. It is also the easiest thing to lose — the first analytics snippet costs all three at once. If measurement becomes necessary, require a self-hosted, cookieless, same-origin solution.

2. Honest uncertainty

The three-tier confidence model, the Tier-3 warning banner, the plumbing disclaimer, and the refusal to show partial filter matches all cost conversions and buy credibility. In a category defined by fear-based marketing, this is the brand. Protect it explicitly in any commercial review.

3. The certification-integrity engine

Isolating NSF 42/372 from health claims, ignoring retired P473, and eliminating partial matches programmatically rather than by editorial judgement is a genuine technical moat. The `/registry` page that names deceptive SKUs turns that engine into content.

4. Accessibility as a default

The no-JS fallback, the reduced-motion floor, the contextual focus ring, the SC 2.4.11 scroll margin. These were designed in, and the reasoning is preserved in code comments so a future contributor cannot remove them by accident.

5. Disclosure quality

The FTC affiliate language is specific, prominent, and repeated at the point of commercial contact. It is better than the legal minimum and should be carried verbatim into the formal policy documents rather than rewritten.

6. The print stylesheet

A water report that survives Ctrl-P — chrome stripped, evidence kept, link targets expanded — because the intended use is to take it to a landlord or a council meeting. This is product empathy expressed in CSS, and it is a genuine differentiator worth marketing.

18 Portfolio Context

Assessed as a member of the niche-utility collection alongside Launch-Window.net and the recipes, sports-analytics and health-tools verticals.

Where it fits

taptoglass.com is the most **commercially ambitious** and the most **operationally demanding** property in the portfolio, and those two facts are connected.

PORTFOLIO TRAIT	CONFORMANCE	NOTES
Privacy-first, no tracking	EXEMPLARY	Cleanest implementation in the portfolio. Should be the reference.
Lightweight, fast, static-first	EXEMPLARY	87.1 kB shared JS, 47 prerendered routes.
Single-purpose utility	STRONG	One job, clearly framed; no feature sprawl.
Deterministic, no per-query LLM	STRONG	Pure set-cover and point-in-polygon. Zero inference cost.
Low operational burden	DIVERGENT	**The exception.** See below.
Affiliate monetization	HIGHEST POTENTIAL	Water filtration has far better economics than launch tracking.

The divergence that matters

This site does not share the portfolio's maintenance profile

Launch-Window.net consumes a public launch API and is essentially self-maintaining. taptoglass.com requires a **weekly SDWIS ingestion pipeline**, **quarterly manual re-verification of NSF certifications** (the README correctly identifies this as unavoidable — there is no bulk certification API), and **ongoing affiliate-link maintenance**. The certification table is simultaneously the moat and the recurring cost. Budget it as a standing quarterly obligation, not a one-time build.

Cross-portfolio leverage

- **Export the design system.** The token architecture, three-state dark mode, focus-ring treatment and print stylesheet are portable. Extracting them into a shared package would lift the whole portfolio and amortise this build.
- **Reuse the disclosure kit.** Once a real privacy policy, terms and contact page exist here, they become templates for every affiliate property in the collection — including the recipe verticals, which face the same FTC requirements.
- **Adopt the confidence-tier pattern.** Any portfolio tool that resolves uncertain inputs — sports projections especially — benefits from the same "show the seam" treatment.

- **Shared health cluster.** This site and the health-tools vertical can interlink credibly on water, hydration and household-exposure topics, building topical authority across two properties rather than one.

Competitive landscape

The niche has three incumbent shapes, and the gap between them is real:

- **EWG Tap Water Database** — dominant authority, enormous coverage, strong domain. Its weakness is that it compares against EWG's own health guidelines rather than federal limits, which reads as advocacy; it is also dated in presentation and offers no certification-matched hardware path.
- **Utility CCR portals and state dashboards** — authoritative and free, but PDF-first, address-hostile, and unusable by a non-specialist.
- **Filter-vendor "water quality checkers"** — fast and well-designed, but owned by manufacturers, so every result routes to the sponsor's own hardware. This is precisely the pattern the `/registry` page documents.

The defensible position is the one the site already claims: **federal limits rather than proprietary guidelines, vendor-agnostic hardware matching, and certification transparency including naming SKUs that overstate their standards.** No incumbent occupies that intersection. It is a real opening — but it requires national coverage to contest, because EWG's advantage is breadth and the current answer to "does it cover me?" is almost always no.

19 Verdict & Recommended Sequence

Verdict

taptoglass.com is a well-built product that has not yet been finished. The distance between its engineering quality and its launch readiness is unusually large, and unusually *cheap to close* — the gap is configuration, legal copy, one manifest string, and a data connection, not architecture. Nothing in this audit recommends a rewrite of anything.

The governing risk is not any single defect but a specific compound failure: a site that **appears** polished and authoritative, tells a user in Denver that nothing was detected in their water, and offers no contact information, no privacy policy, and a canonical tag pointing at a different domain. Each of those is individually fixable in hours. Together, and left unaddressed, they would make the site's own trust-first positioning counterfactual.

Recommended sequence

1. **Verify the production origin first.** Confirm `NEXT_PUBLIC_SITE_URL` is set to `https://taptoglass.com`. Nothing else in SEO matters until this is known. *(Minutes.)*
2. **Resolve the brand decision.** Either rename the product to Tap to Glass throughout, or move the site to waterqualitylens.com. The current state — one name in the code, another in the address bar — is the worst of both. *(Hours, once decided.)*
3. **Ship the legal and contact layer.** Privacy policy, terms, contact page. This unblocks AdSense, affiliate programmes, and the YMYL trust signal simultaneously. *(One day.)*
4. **Connect real data.** Deploy the Worker, populate the D1 bindings, run the SDWIS ingestion. This is the item that converts every other improvement into revenue. *(The real project.)*
5. **Then** pursue content, schema and monetization expansion.

> **A closing note on what this team built**
>
> It is worth stating plainly that the front-end craft here — the token system, the accessibility reasoning preserved in comments, the no-JS fallback, the print stylesheet, the refusal to show partial matches — is materially better than what this audit typically finds in funded consumer properties. The findings in this report are about what was not yet connected, not about what was built badly.